Vertrag zur Auftragsverarbeitung (Art. 28 DSGVO)

Ein Mustervertrag zwischen einem Verantwortlichen und einem Auftragsverarbeiter nach Art. 28 DSGVO, mit vier auszufüllenden Anlagen und einer zeilenweisen Prüfliste für einen bereits unterschriebenen Vertrag. Für Datenschutzbeauftragte, Rechtsanwältinnen und Rechtsanwälte und Inhaber kleiner Unternehmen.

FÜR WEN

Deutsche Ausgabe. Die Hinweise für Italien stehen in der englischen Ausgabe: https://finoprivacy.com/documents/processor-agreement.html (auf Englisch). Für Verantwortliche und Auftragsverarbeiter in der EU, öffentlich oder privat, die den schriftlichen Vertrag nach Art. 28 der Datenschutz-Grundverordnung (DSGVO) brauchen. Das Muster folgt dem EU-Recht; die deutschen Besonderheiten stehen in einem eigenen Abschnitt.

NICHT ABGEDECKT

Gemeinsam Verantwortliche (Art. 26 DSGVO) und eigenständige Verantwortliche, die ein anderes Dokument brauchen. Die Übermittlungsinstrumente selbst (Standardvertragsklauseln für Übermittlungen, Transfer-Folgenabschätzungen). Verarbeitung zu Zwecken der Strafverfolgung nach der Richtlinie (EU) 2016/680 (in Deutschland Teil 3 des BDSG, § 62) und Verarbeitung durch Organe der EU nach der Verordnung (EU) 2018/1725. Kaufmännische Bedingungen wie Preis, Haftungsgrenzen und Versicherung, die als Felder offenbleiben.

RECHTSSTAND

DSGVO (Verordnung (EU) 2016/679), deutsche Fassung auf EUR-Lex, gelesen am 8. November 2026; Durchführungsbeschluss (EU) 2021/915 der Kommission vom 4. Juni 2021, deutsche Fassung, gelesen am 8. November 2026; EDSA-Leitlinien 07/2020 zu den Begriffen „Verantwortlicher" und „Auftragsverarbeiter", deutsche Fassung, Version 2.0 vom 7. Juli 2021, gelesen am 8. November 2026; EDSA-Stellungnahme 22/2024 vom 7. Oktober 2024, deutsche Fassung, gelesen am 8. November 2026; Gemeinsame Stellungnahme 1/2021 von EDSA und EDSB vom 14. Januar 2021 (auf Englisch; der Inhalt ist aus der englischen Ausgabe übernommen, gelesen dort am 7. November 2026); EDSA-Register der Klauseln nach Art. 28 Abs. 8, gelesen am 7. November 2026; § 203 StGB und § 43e BRAO (gesetze-im-internet.de, gelesen am 8. November 2026); BfDI-Mustervereinbarung zur Auftragsverarbeitung, Version 2.1, gelesen am 8. November 2026; DSK Kurzpapier Nr. 13 (Stand: 17. Dezember 2018, von der DSK als „in Überarbeitung" geführt), gelesen am 8. November 2026.

VERSION

1.0, 8. November 2026

Abkürzungen: Art. = Artikel, Abs. = Absatz, Buchst. = Buchstabe, Nr. = Nummer, S. = Seite, Ziffer = nummerierter Absatz der EDSA-Leitlinien.

Vor der Verwendung prüfen

Ist die andere Partei Auftragsverarbeiter? Art. 28 gilt nur, wenn eine andere Stelle personenbezogene Daten im Auftrag des Verantwortlichen verarbeitet (Art. 4 Nr. 8 DSGVO). **Zwei Wege.** Die Parteien können einen eigenen Vertrag oder ein anderes Rechtsinstrument schließen (Art. 28 Abs. 3 DSGVO), wie in diesem Muster, oder Standardvertragsklauseln verwenden, die die Kommission (Art. 28 Abs. 7: Durchführungsbeschluss (EU) 2021/915) oder eine Aufsichtsbehörde (Art. 28 Abs. 8) festgelegt hat. In beiden Fällen ist der Vertrag *„schriftlich abzufassen, was auch in einem elektronischen Format erfolgen kann"* (Art. 28 Abs. 9). **Fehler aus Bußgeldfällen:** gar kein Vertrag, ein Unterauftragsverarbeiter ohne Genehmigung, ein Auftragsverarbeiter, der eigenmächtig handelt, ein Verantwortlicher, der seine Auftragsverarbeiter nicht kontrolliert (Fälle unter der Prüfliste und im Abschnitt zu Deutschland). **Nicht für** gemeinsam Verantwortliche (Art. 26) oder zwei eigenständige Verantwortliche.

Vor der Verwendung des Musters

Wer Auftragsverarbeiter ist

Auftragsverarbeiter ist *„eine natürliche oder juristische Person, Behörde, Einrichtung oder andere Stelle, die personenbezogene Daten im Auftrag des Verantwortlichen verarbeitet"* (Art. 4 Nr. 8 DSGVO). Verantwortlicher ist, wer über die Zwecke und Mittel der Verarbeitung entscheidet (Art. 4 Nr. 7). Der Europäische Datenschutzausschuss (EDSA), das Gremium der Aufsichtsbehörden der EU, schreibt: *„Für die Einstufung als Auftragsverarbeiter gelten zwei grundlegende Voraussetzungen"*: Der Auftragsverarbeiter ist eine vom Verantwortlichen getrennte Stelle, und er verarbeitet die Daten in dessen Auftrag (EDSA-Leitlinien 07/2020, S. 4).

Die Bezeichnung im Vertrag entscheidet nicht über die Rolle. Entspricht ein Vertrag nicht den tatsächlichen Verhältnissen, *„so kann die Vereinbarung auf der Grundlage einer faktischen Analyse der Umstände der Beziehung zwischen den Parteien und der durchgeführten Verarbeitung personenbezogener Daten aufgehoben werden"* (EDSA-Leitlinien 07/2020, Fußnote 42, S. 37). Ein Anbieter, der die Daten für eigene Zwecke nutzt, ist Verantwortlicher. Im Beispiel des EDSA sind ein Reisebüro und die Fluggesellschaften und Hotels, an die es Buchungen weitergibt, jeweils Verantwortliche, ohne Auftragsverarbeiter dazwischen (Ziffer 92, S. 35).

Zwei Wege: eigener Vertrag oder Standardvertragsklauseln

Art. 28 Abs. 3 verlangt einen Vertrag oder ein anderes Rechtsinstrument *„nach dem Unionsrecht oder dem Recht der Mitgliedstaaten, der bzw. das den Auftragsverarbeiter in Bezug auf den Verantwortlichen bindet"* (Art. 28 DSGVO). Die Parteien können einen eigenen Vertrag schreiben oder ihn *„ganz oder teilweise"* auf Standardvertragsklauseln stützen (Art. 28 Abs. 6). Der EDSA stellt klar, dass Verantwortliche und Auftragsverarbeiter *„weder verpflichtet sind, einen Vertrag auf der Grundlage von Standardvertragsklauseln abzuschließen, noch dass diese zwangsläufig der Aushandlung eines individuellen Vertrags vorzuziehen sind"* (EDSA-Leitlinien 07/2020, Ziffer 106, S. 38).

Die Klauseln der Kommission. Die Klauseln im Anhang des Durchführungsbeschlusses (EU) 2021/915 *„erfüllen die Anforderungen an Verträge zwischen Verantwortlichen und Auftragsverarbeitern gemäß Artikel 28 Absätze 3 und 4"* (Artikel 1 des Beschlusses). Sie werden unverändert verwendet: *„Die Parteien verpflichten sich, die Klauseln nicht zu ändern, es sei denn, zur Ergänzung oder Aktualisierung der in den Anhängen angegebenen Informationen"* (Klausel 2 Buchst. a). Sie dürfen in einen umfangreicheren Vertrag aufgenommen werden, mit weiteren Klauseln, die ihnen nicht widersprechen (Klausel 2 Buchst. b). Sie *„stellen für sich allein genommen nicht sicher, dass die Verpflichtungen im Zusammenhang mit internationalen Datenübermittlungen gemäß Kapitel V"* der DSGVO erfüllt werden (Klausel 1 Buchst. f): Übermittlungen in Drittländer brauchen ein eigenes Instrument.

Klauseln einer Aufsichtsbehörde. Das Register des EDSA für Klauseln nach Art. 28 Abs. 8 nennt drei Sätze: Dänemark (10. Dezember 2019), Litauen und Slowenien (beide 13. April 2023). Klauseln einer italienischen oder deutschen Behörde nennt es nicht (EDSA-Register, auf Englisch, gelesen am 7. November 2026).

Dieses Muster sind nicht die Klauseln der Kommission. Es ist ein individueller Vertrag nach Art. 28 Abs. 3 in eigener Formulierung von Fino. Es folgt der Reihenfolge von Art. 28 Abs. 3 und dem Aufbau der in den Quellen genannten amtlichen Muster, nicht deren Wortlaut. Wer sich auf die Klauseln der Kommission stützen will, verwendet den amtlichen Text unverändert.

Konkret, keine Wiederholung des Gesetzes

Nach dem EDSA sollten in der Vereinbarung *„nicht lediglich die Bestimmungen der DSGVO wiederholt werden"*; sie sollte konkret sagen, wie die Vorgaben eingehalten werden (EDSA-Leitlinien 07/2020, Ziffer 112, S. 40). Deshalb stehen die Einzelheiten in diesem Muster in vier Anlagen. Ein Vertrag, der vor dem Geltungsbeginn der DSGVO geschlossen und nie angepasst wurde, verstößt nach dem EDSA gegen Art. 28 Abs. 3 (Ziffer 103, S. 37).

Der Mustervertrag

Füllen Sie jedes Feld aus. Wo das Muster Optionen bietet, behalten Sie eine und streichen Sie die übrigen. Jede kursive Zeile erklärt die Klausel darüber in einfachen Worten; streichen Sie diese Zeilen vor der Unterzeichnung.

1. Parteien und Gegenstand

1.1 Dieser Vertrag zur Auftragsverarbeitung wird geschlossen zwischen NAME, ANSCHRIFT UND REGISTERNUMMER DES VERANTWORTLICHEN („Verantwortlicher“) und NAME, ANSCHRIFT UND REGISTERNUMMER DES AUFTRAGSVERARBEITERS („Auftragsverarbeiter“). Er regelt die Verarbeitung personenbezogener Daten, die der Auftragsverarbeiter im Auftrag des Verantwortlichen aufgrund von BEZEICHNUNG UND DATUM DES HAUPTVERTRAGS („Hauptvertrag“) durchführt.

Art. 28 Abs. 3 DSGVO

Nennt die beiden Parteien und verbindet diesen Vertrag mit dem Leistungsvertrag, zu dem er gehört.

1.2 Begriffe, die in der DSGVO bestimmt sind, etwa personenbezogene Daten, Verarbeitung, betroffene Person und Verletzung des Schutzes personenbezogener Daten, haben die Bedeutung nach Art. 4 DSGVO.

Art. 4 DSGVO

Die Rechtsbegriffe bedeuten, was die DSGVO sagt. Betroffene Person: die Person, um deren Daten es geht. Aufsichtsbehörde: die staatliche Datenschutzbehörde.

1.3 Widerspricht dieser Vertrag dem Hauptvertrag oder einer anderen Vereinbarung der Parteien zum Schutz personenbezogener Daten, geht dieser Vertrag vor. Das gilt nicht für von der Kommission erlassene Standardvertragsklauseln, die die Parteien unterzeichnet haben; widersprechen sie diesem Vertrag, gehen sie vor, wie sie es selbst vorsehen.

EDSA-Leitlinien 07/2020, Ziffer 103; Beschluss 2021/914, Anhang, Klausel 5; Beschluss 2021/915, Anhang, Klausel 4

Die Datenschutzregeln gehen dem kaufmännischen Vertrag vor, die Standardklauseln der Kommission, falls unterzeichnet, aber diesem Vertrag. Der EDSA empfiehlt, die Regeln nach Art. 28 an einer Stelle zusammenzuhalten.

2. Die Verarbeitung

2.1 Anlage 1 beschreibt Gegenstand und Dauer der Verarbeitung, Art und Zweck der Verarbeitung, die Art der personenbezogenen Daten und die Kategorien betroffener Personen. Der Auftragsverarbeiter verarbeitet die personenbezogenen Daten nur für die in Anlage 1 genannten Zwecke.

Art. 28 Abs. 3 Unterabs. 1 DSGVO

Anlage 1 sagt, was verarbeitet wird, über wen, wie, wozu und wie lange.

Der EDSA verlangt Genauigkeit: Die Art der personenbezogenen Daten *„sollte so detailliert wie möglich angegeben werden“*, und die bloße Angabe *„personenbezogene Daten gemäß Artikel 4 Nr. 1 DSGVO“* genügt nicht (EDSA-Leitlinien 07/2020, Ziffer 114, S. 41).

3. Pflichten und Rechte des Verantwortlichen

3.1 Der Verantwortliche bleibt dafür verantwortlich, dass die dem Auftragsverarbeiter übertragene Verarbeitung der DSGVO entspricht. Er stellt dem Auftragsverarbeiter die in Anlage 1 beschriebenen personenbezogenen Daten zur Verfügung, erteilt seine Weisungen in dokumentierter Form und kann vor und während der Verarbeitung prüfen, ob der Auftragsverarbeiter diesen Vertrag und die DSGVO einhält, auch durch Überprüfungen nach Ziffer 12.

Art. 28 Abs. 3 und Art. 24 DSGVO; EDSA-Leitlinien 07/2020, Ziffer 114

Art. 28 Abs. 3 verlangt, dass der Vertrag auch die Pflichten und Rechte des Verantwortlichen festlegt.

4. Weisungen

4.1 Der Auftragsverarbeiter verarbeitet die personenbezogenen Daten nur auf dokumentierte Weisung des Verantwortlichen, auch in Bezug auf die Übermittlung personenbezogener Daten an ein Drittland oder eine internationale Organisation, sofern er nicht durch das Recht der Union oder der Mitgliedstaaten, dem er unterliegt, hierzu verpflichtet ist. In einem solchen Fall teilt er dem Verantwortlichen diese rechtlichen Anforderungen vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.

Art. 28 Abs. 3 Buchst. a DSGVO

Der Auftragsverarbeiter handelt nur auf Weisung des Verantwortlichen. Verlangt ein Gesetz der EU oder eines Mitgliedstaats etwas anderes, sagt er das vorher, außer das Gesetz verbietet es.

4.2 Dieser Vertrag und seine Anlagen sind die ersten Weisungen des Verantwortlichen. Weitere Weisungen erteilt der Verantwortliche schriftlich, auch per E-Mail, durch die in Anlage 4 genannten Personen. Beide Parteien bewahren jede Weisung zusammen mit diesem Vertrag auf.

Art. 28 Abs. 3 Buchst. a DSGVO; EDSA-Leitlinien 07/2020, Ziffer 118

Jede spätere Weisung wird festgehalten und aufbewahrt, damit sie sich später nachweisen lässt.

4.3 Der Auftragsverarbeiter informiert den Verantwortlichen unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen die DSGVO oder gegen andere Datenschutzbestimmungen der Union oder der Mitgliedstaaten verstößt. Er kann die Durchführung dieser Weisung aussetzen, bis der Verantwortliche sie bestätigt, ändert oder zurückzieht.

Art. 28 Abs. 3 Unterabs. 2 DSGVO; EDSA-Leitlinien 07/2020, Ziffer 149

Hält der Auftragsverarbeiter eine Weisung für rechtswidrig, sagt er das sofort. Der zweite Satz zur Aussetzung ist freiwillig: Der EDSA nennt ihn als Beispiel. Streichen Sie ihn, wenn die Parteien ihn nicht vereinbaren.

Art. 28 Abs. 3 regelt diese Pflicht in einem eigenen Unterabsatz: *„Mit Blick auf Unterabsatz 1 Buchstabe h informiert der Auftragsverarbeiter den Verantwortlichen unverzüglich, falls er der Auffassung ist, dass eine Weisung gegen diese Verordnung oder gegen andere Datenschutzbestimmungen der Union oder der Mitgliedstaaten verstößt“* (Art. 28 DSGVO). Was danach geschieht, sagt die DSGVO nicht. Der EDSA empfiehlt, es zu regeln, etwa die Aussetzung der Weisung oder die Kündigung, wenn der Verantwortliche an ihr festhält (EDSA-Leitlinien 07/2020, Ziffer 149, S. 49). Ziffer 15.3 sieht die Kündigung vor.

4.4 Der Auftragsverarbeiter verarbeitet die personenbezogenen Daten weder für eigene Zwecke noch für Zwecke Dritter. Bestimmt er unter Verstoß gegen die DSGVO die Zwecke und Mittel der Verarbeitung, gilt er in Bezug auf diese Verarbeitung als Verantwortlicher.

Art. 28 Abs. 10 DSGVO

Ein Auftragsverarbeiter, der anfängt zu entscheiden, warum und wie die Daten verwendet werden, wird für diese Nutzung zum Verantwortlichen, mit den Pflichten eines Verantwortlichen.

Zu der Wendung *„sofern er nicht durch das Recht der Union oder der Mitgliedstaaten, dem der Auftragsverarbeiter unterliegt, hierzu verpflichtet ist“* hält der EDSA ihre Aufnahme für *„dringend zu empfehlen, aber nicht verpflichtend“*. Bei Daten, die außerhalb des Europäischen Wirtschaftsraums (EWR: die EU sowie Island, Liechtenstein und Norwegen) übermittelt werden, hält er es für unwahrscheinlich, dass eine weitere Formulierung wie *„sofern er nicht durch das geltende Recht oder eine verbindliche Anordnung einer staatlichen Stelle hierzu verpflichtet ist“* für sich genommen ausreicht (EDSA-Stellungnahme 22/2024, Zusammenfassung, S. 3 und 4).

5. Vertraulichkeit

5.1 Der Auftragsverarbeiter gewährt Zugang zu den personenbezogenen Daten nur den Beschäftigten, die ihn zur Erfüllung des Hauptvertrags benötigen. Er gewährleistet, dass sich die zur Verarbeitung der personenbezogenen Daten befugten Personen zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen. Die Verpflichtung umfasst alle für den Verantwortlichen verarbeiteten personenbezogenen Daten und gilt nach dem Ende der Tätigkeit der Person fort.

Art. 28 Abs. 3 Buchst. b DSGVO; EDSA-Leitlinien 07/2020, Ziffern 123 und 124

Nur wer die Daten braucht, sieht sie, und jede dieser Personen ist zur Verschwiegenheit verpflichtet, durch Vertrag oder Gesetz.

5.2 Der Auftragsverarbeiter stellt sicher, dass ihm unterstellte Personen, die Zugang zu den personenbezogenen Daten haben, diese nur auf Weisung des Verantwortlichen verarbeiten, es sei denn, sie sind nach dem Recht der Union oder der Mitgliedstaaten zur Verarbeitung verpflichtet.

Art. 29 und Art. 32 Abs. 4 DSGVO

Alle, die unter dem Auftragsverarbeiter arbeiten, folgen ebenfalls den Weisungen des Verantwortlichen.

6. Sicherheit

6.1 Der Auftragsverarbeiter ergreift alle gemäß Art. 32 DSGVO erforderlichen Maßnahmen. Er setzt mindestens die in Anlage 2 beschriebenen technischen und organisatorischen Maßnahmen um, die die Parteien unter Berücksichtigung des Stands der Technik, der Implementierungskosten, der Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung sowie der Risiken für die Rechte und Freiheiten natürlicher Personen gewählt haben.

Art. 28 Abs. 3 Buchst. c und Art. 32 Abs. 1 DSGVO

Der Auftragsverarbeiter schützt die Daten auf dem Niveau, das das Risiko verlangt. Anlage 2 nennt die konkreten Maßnahmen.

6.2 Der Auftragsverarbeiter überprüft die Maßnahmen mindestens PRÜFINTERVALL, ZUM BEISPIEL ALLE 12 MONATE und nach jeder wesentlichen Änderung der Verarbeitung. Er ersetzt eine Maßnahme nur durch eine, die mindestens das gleiche Sicherheitsniveau bietet. Wesentliche Änderungen teilt er dem Verantwortlichen vorab mit und nimmt sie nur mit dessen schriftlicher Zustimmung vor.

Art. 32 Abs. 1 Buchst. d DSGVO; EDSA-Leitlinien 07/2020, Ziffer 126

Die Maßnahmen werden regelmäßig geprüft und nie ohne Zustimmung des Verantwortlichen abgeschwächt.

7. Unterauftragsverarbeiter

Behalten Sie Option A oder Option B und streichen Sie die andere.

7.1 **Option A, gesonderte Genehmigung.** Der Auftragsverarbeiter nimmt keinen weiteren Auftragsverarbeiter (Unterauftragsverarbeiter) ohne vorherige gesonderte schriftliche Genehmigung des Verantwortlichen in Anspruch. Er stellt jeden Antrag mindestens ANZAHL Tage vor der Beauftragung, mit den in Anlage 3 genannten Angaben. Ein Antrag, der innerhalb dieser Frist nicht beantwortet wird, gilt als abgelehnt.

Art. 28 Abs. 2 DSGVO; EDSA-Leitlinien 07/2020, Ziffern 152 bis 155

Jeder neue Unterauftragsverarbeiter braucht das schriftliche Ja des Verantwortlichen. Schweigen bedeutet Nein.

7.2 **Option B, allgemeine Genehmigung.** Der Verantwortliche erteilt seine allgemeine schriftliche Genehmigung für die in Anlage 3 aufgeführten Unterauftragsverarbeiter. Der Auftragsverarbeiter informiert den Verantwortlichen mindestens ANZAHL Tage im Voraus schriftlich über jede beabsichtigte Hinzuziehung oder Ersetzung eines Unterauftragsverarbeiters, mit den in Anlage 3 genannten Angaben, damit der Verantwortliche Einspruch erheben kann. Erhebt der Verantwortliche Einspruch, FOLGE EINES EINSPRUCHS.

Art. 28 Abs. 2 DSGVO; EDSA-Leitlinien 07/2020, Ziffern 156 bis 158

Der Verantwortliche stimmt vorab einer Liste zu. Der Auftragsverarbeiter kündigt jede Änderung an, und der Verantwortliche kann Nein sagen. Schreiben Sie in das Feld, was auf einen Einspruch folgt, zum Beispiel: Der Auftragsverarbeiter beauftragt den Unterauftragsverarbeiter nicht, oder jede Partei kann die betroffene Leistung innerhalb einer bestimmten Zahl von Tagen kündigen.

Die Informationspflicht ist aktiv. Nach dem EDSA reicht es *„nicht aus, dass der Auftragsverarbeiter dem Verantwortlichen lediglich allgemeinen Zugang zu einer Liste der Unterauftragsverarbeiter gewährt, die möglicherweise von Zeit zu Zeit aktualisiert wird, ohne auf jeden neuen vorgesehenen Unterauftragsverarbeiter hinzuweisen“* (EDSA-Leitlinien 07/2020, Fußnote 54, S. 44). Bei einer allgemeinen Genehmigung kann das Schweigen des Verantwortlichen innerhalb der vereinbarten Frist als Genehmigung gelten (Ziffer 157, S. 50).

7.3 Nimmt der Auftragsverarbeiter einen Unterauftragsverarbeiter in Anspruch, um bestimmte Verarbeitungstätigkeiten im Namen des Verantwortlichen auszuführen, so erlegt er ihm im Wege eines Vertrags oder eines anderen Rechtsinstruments nach dem Unionsrecht oder dem Recht des betreffenden Mitgliedstaats dieselben Datenschutzpflichten auf, die in diesem Vertrag festgelegt sind, insbesondere hinreichende Garantien dafür, dass geeignete technische und organisatorische Maßnahmen durchgeführt werden. Dazu gehört das Recht des Verantwortlichen oder eines von ihm beauftragten Prüfers, den Unterauftragsverarbeiter zu überprüfen.

Art. 28 Abs. 4 DSGVO; EDSA-Leitlinien 07/2020, Ziffern 129 und 160

Dieselben Pflichten gelten entlang der Kette. Der Wortlaut darf abweichen, der Inhalt nicht.

7.4 Kommt ein Unterauftragsverarbeiter seinen Datenschutzpflichten nicht nach, haftet der Auftragsverarbeiter gegenüber dem Verantwortlichen für die Einhaltung der Pflichten jenes Unterauftragsverarbeiters.

Art. 28 Abs. 4 Satz 2 DSGVO

Der Auftragsverarbeiter steht gegenüber dem Verantwortlichen für seine Unterauftragsverarbeiter ein.

7.5 Der Auftragsverarbeiter hält Anlage 3 mit Name, Anschrift, Ansprechpartner, Verarbeitungstätigkeit und Ort jedes Unterauftragsverarbeiters auf jeder Stufe der Kette aktuell. Auf Verlangen des Verantwortlichen stellt er eine Kopie eines Vertrags mit einem Unterauftragsverarbeiter und etwaiger Änderungen zur Verfügung; er darf Text nur schwärzen, soweit es zum Schutz von Geschäftsgeheimnissen oder anderen vertraulichen Informationen, einschließlich personenbezogener Daten, erforderlich ist.

EDSA-Stellungnahme 22/2024, Zusammenfassung; Beschluss 2021/915, Anhang, Klausel 7.7 Buchst. c

Der Verantwortliche weiß immer, wer seine Daten verarbeitet, die ganze Kette hinunter.

8. Anträge betroffener Personen

8.1 Der Auftragsverarbeiter unterstützt den Verantwortlichen angesichts der Art der Verarbeitung nach Möglichkeit mit geeigneten technischen und organisatorischen Maßnahmen dabei, seiner Pflicht zur Beantwortung von Anträgen auf Wahrnehmung der in Kapitel III DSGVO genannten Rechte der betroffenen Person nachzukommen. Anlage 2 Teil B beschreibt diese Maßnahmen.

Art. 28 Abs. 3 Buchst. e DSGVO

Der Auftragsverarbeiter hilft dem Verantwortlichen, Personen zu antworten, die ihre Daten einsehen, berichtigen, löschen oder übertragen lassen wollen.

8.2 Der Auftragsverarbeiter leitet jeden Antrag einer betroffenen Person, den er erhält, innerhalb von ANZAHL Arbeitstagen an den Verantwortlichen weiter und beantwortet ihn nicht selbst, es sei denn, der Verantwortliche ermächtigt ihn schriftlich dazu.

EDSA-Leitlinien 07/2020, Ziffern 131 und 132

Der Verantwortliche entscheidet über jeden Antrag. Seine gesetzlichen Fristen laufen weiter, während er auf den Auftragsverarbeiter wartet.

9. Unterstützung bei Sicherheit, Verletzungen und Folgenabschätzungen

9.1 Der Auftragsverarbeiter unterstützt den Verantwortlichen unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Einhaltung der in den Art. 32 bis 36 DSGVO genannten Pflichten: Sicherheit der Verarbeitung, Meldung von Verletzungen des Schutzes personenbezogener Daten an die Aufsichtsbehörde und Benachrichtigung der betroffenen Personen, Datenschutz-Folgenabschätzung und vorherige Konsultation der Aufsichtsbehörde. Anlage 2 Teil B beschreibt, wie.

Art. 28 Abs. 3 Buchst. f DSGVO

Der Auftragsverarbeiter hilft bei den Pflichten des Verantwortlichen zu Sicherheit, Meldungen von Verletzungen, Folgenabschätzungen und Konsultation der Aufsichtsbehörde.

10. Verletzungen des Schutzes personenbezogener Daten

10.1 Der Auftragsverarbeiter meldet dem Verantwortlichen jede Verletzung des Schutzes der nach diesem Vertrag verarbeiteten personenbezogenen Daten, auch bei einem Unterauftragsverarbeiter, unverzüglich, nachdem sie ihm bekannt wurde, und in jedem Fall innerhalb von ANZAHL Stunden, über KANAL, ZUM BEISPIEL E-MAIL UND TELEFON an die Kontaktstelle in Anlage 4.

Art. 33 Abs. 2 DSGVO; EDSA-Leitlinien 07/2020, Ziffer 136

Die DSGVO nennt für den Auftragsverarbeiter keine Stundenzahl; nach dem EDSA können die Parteien eine vereinbaren. Der Verantwortliche selbst muss die Aufsichtsbehörde unverzüglich und möglichst binnen 72 Stunden, nachdem ihm die Verletzung bekannt wurde, benachrichtigen (Art. 33 Abs. 1).

Der EDSA: Je nach den Besonderheiten der Verarbeitung *„kann es angebracht sein, dass die Parteien in den Vertrag einen bestimmten Zeitrahmen (z. B. eine bestimmte Anzahl von Stunden) aufnehmen, innerhalb dessen der Auftragsverarbeiter den Verantwortlichen benachrichtigen"* sollte (EDSA-Leitlinien 07/2020, Ziffer 136, S. 46). Der Entwurf der Kommissionsklauseln sah 48 Stunden vor; EDSA und Europäischer Datenschutzbeauftragter (EDSB) schlugen vor, die Frist den Parteien zu überlassen (Gemeinsame Stellungnahme 1/2021, Ziffer 42, auf Englisch), und die erlassenen Klauseln sagen *„unverzüglich, nachdem ihm die Verletzung bekannt wurde"*, ohne Stundenzahl (Beschluss 2021/915, Anhang, Klausel 9.2).

10.2 Die Meldung enthält, soweit möglich: eine Beschreibung der Art der Verletzung, einschließlich der Kategorien und der ungefähren Zahl der betroffenen Personen und der ungefähren Zahl der betroffenen Datensätze; eine Kontaktstelle für weitere Informationen; die wahrscheinlichen Folgen; und die ergriffenen oder vorgeschlagenen Maßnahmen zur Behebung der Verletzung und zur Abmilderung ihrer möglichen nachteiligen Auswirkungen. Informationen, die noch nicht vorliegen, werden schrittweise ohne unangemessene weitere Verzögerung nachgereicht.

Art. 28 Abs. 3 Buchst. f und Art. 33 Abs. 3 und 4 DSGVO

Die Meldung gibt dem Verantwortlichen, was er für seine eigene Meldung an die Aufsichtsbehörde braucht.

10.3 Der Auftragsverarbeiter meldet Verletzungen weder der Aufsichtsbehörde noch benachrichtigt er betroffene Personen im Namen des Verantwortlichen, es sei denn, der Verantwortliche weist ihn schriftlich dazu an. Tut er es auf Weisung, sendet er dem Verantwortlichen eine Kopie der Meldung und der Benachrichtigung.

EDSA-Leitlinien 07/2020, Ziffer 136

Die Meldung an die Aufsichtsbehörde bleibt eine gesetzliche Pflicht des Verantwortlichen, auch wenn der Auftragsverarbeiter sie absendet.

11. Ende der Verarbeitung

11.1 Nach Abschluss der Erbringung der Verarbeitungsleistungen löscht der Auftragsverarbeiter nach Wahl des Verantwortlichen alle personenbezogenen Daten oder gibt sie ihm zurück und löscht die vorhandenen Kopien, sofern nicht nach dem Unionsrecht oder dem Recht der Mitgliedstaaten eine Verpflichtung zur Speicherung der personenbezogenen Daten besteht. Der Verantwortliche wählt: WAHL DES VERANTWORTLICHEN. Er kann seine Wahl bis zum Ende der Leistungen schriftlich ändern.

Art. 28 Abs. 3 Buchst. g DSGVO; EDSA-Leitlinien 07/2020, Ziffer 140

Am Ende entscheidet der Verantwortliche: Daten zurück oder gelöscht, Kopien eingeschlossen. Schreiben Sie in das Feld entweder Löschung oder Rückgabe und das Format der Rückgabe.

11.2 Der Auftragsverarbeiter schließt die Löschung oder Rückgabe innerhalb von ANZAHL Tagen ab, löscht sicher und bestätigt dies schriftlich. Muss er nach einem Gesetz einen Teil der Daten aufbewahren, teilt er dem Verantwortlichen so bald wie möglich mit, welches Gesetz und welche Daten, und schützt diese Daten bis zu ihrer Löschung weiter nach diesem Vertrag.

EDSA-Leitlinien 07/2020, Ziffern 141 und 142

Die Löschung wird schriftlich bestätigt. Daten, die ein Gesetz aufzubewahren verlangt, bleiben geschützt.

12. Informationen und Überprüfungen

12.1 Der Auftragsverarbeiter stellt dem Verantwortlichen alle erforderlichen Informationen zum Nachweis der Einhaltung der in Art. 28 DSGVO niedergelegten Pflichten zur Verfügung, einschließlich Angaben zu den eingesetzten Systemen, den Sicherheitsmaßnahmen, dem Ort der Daten, Übermittlungen, den Zugriffsberechtigten und den eingesetzten Unterauftragsverarbeitern.

Art. 28 Abs. 3 Buchst. h DSGVO; EDSA-Leitlinien 07/2020, Ziffer 143

Der Verantwortliche kann alles verlangen, was er braucht, um zu zeigen, dass die Verarbeitung in Ordnung ist.

12.2 Der Auftragsverarbeiter ermöglicht Überprüfungen, einschließlich Inspektionen, die vom Verantwortlichen oder einem anderen von diesem beauftragten Prüfer durchgeführt werden, mit einer Vorankündigung von ANZAHL Tagen oder kürzer, wenn es Anzeichen für Verstöße gibt, und trägt dazu bei. Der Auftragsverarbeiter kann einen Prüfer vorschlagen; der Verantwortliche entscheidet. Der Verantwortliche kann Zertifizierungen und Prüfberichte des Auftragsverarbeiters berücksichtigen.

Art. 28 Abs. 3 Buchst. h DSGVO; EDSA-Leitlinien 07/2020, Ziffer 144; Beschluss 2021/915, Anhang, Klausel 7.6

Der Verantwortliche oder ein von ihm gewählter Prüfer kann den Auftragsverarbeiter kontrollieren, wenn nötig vor Ort.

12.3 Die Kosten der Überprüfungen werden wie folgt getragen: KOSTENREGEL. Kein Entgelt darf so hoch sein, dass es den Verantwortlichen davon abhält, seine Rechte nach dieser Ziffer auszuüben.

EDSA-Leitlinien 07/2020, Ziffer 145

Die DSGVO sagt nicht, wer Überprüfungen bezahlt. Der EDSA warnt vor so hohen Entgelten, dass Überprüfungen nur auf dem Papier stehen.

13. Internationale Übermittlungen

13.1 Der Auftragsverarbeiter übermittelt personenbezogene Daten an ein Drittland oder eine internationale Organisation nur auf dokumentierte Weisung des Verantwortlichen oder wenn das Recht der Union oder der Mitgliedstaaten, dem er unterliegt, es verlangt, und in beiden Fällen nur im Einklang mit Kapitel V DSGVO. Dasselbe gilt für Übermittlungen durch seine Unterauftragsverarbeiter.

Art. 28 Abs. 3 Buchst. a und Art. 44 DSGVO; EDSA-Leitlinien 07/2020, Ziffern 119 und 120

Daten gehen nur in ein Drittland, wenn der Verantwortliche es anweist und ein gültiges Übermittlungsinstrument besteht.

13.2 Der Verantwortliche genehmigt folgende Übermittlungen: GENEHMIGTE ÜBERMITTLUNGEN, ODER: KEINE.

Art. 44 bis 47 DSGVO

Nennen Sie für jede Übermittlung das Land, den Empfänger, den Zweck und das Instrument, das sie zulässig macht: einen Angemessenheitsbeschluss (Art. 45), Standarddatenschutzklauseln (Art. 46 Abs. 2 Buchst. c), verbindliche interne Datenschutzvorschriften (Art. 47) oder ein anderes Instrument nach Kapitel V. Gibt es keines, schreiben Sie: keine.

Die Auftragsverarbeiterklauseln der Kommission *„stellen für sich allein genommen nicht sicher, dass die Verpflichtungen im Zusammenhang mit internationalen Datenübermittlungen gemäß Kapitel V“* der DSGVO erfüllt werden (Beschluss 2021/915, Anhang, Klausel 1 Buchst. f). Sitzt der Auftragsverarbeiter außerhalb des räumlichen Anwendungsbereichs der DSGVO, *„erfüllen“* die Übermittlungsklauseln der Kommission (Durchführungsbeschluss (EU) 2021/914) *„auch die Anforderungen gemäß Artikel 28 Absätze 3 und 4“* (Beschluss 2021/915, Erwägungsgrund 10).

14. Haftung und Kosten

14.1 Jede Partei haftet gegenüber betroffenen Personen nach Art. 82 DSGVO. Dieser Vertrag beschränkt die Rechte betroffener Personen nach diesem Artikel nicht.

Art. 82 DSGVO

Gegenüber den betroffenen Personen entscheidet Art. 82: Ein Auftragsverarbeiter haftet nur, wenn er seinen speziell den Auftragsverarbeitern auferlegten Pflichten nicht nachgekommen ist oder außerhalb oder entgegen den rechtmäßig erteilten Weisungen des Verantwortlichen gehandelt hat.

14.2 Die Haftung zwischen den Parteien, einschließlich etwaiger Begrenzungen, richtet sich nach HAFTUNGSREGELUNG.

Art. 82 Abs. 5 DSGVO

Nach Art. 82 Abs. 5 kann eine Partei, die vollen Schadenersatz geleistet hat, von der anderen deren Anteil zurückfordern. Jede andere Aufteilung vereinbaren die Parteien. Verweisen Sie im Feld auf die Haftungsregeln des Hauptvertrags oder schreiben Sie die Regeln aus.

14.3 Die Unterstützung des Auftragsverarbeiters nach den Ziffern 8, 9, 10 und 12 ist PREIS DER UNTERSTÜTZUNG.

Art. 28 Abs. 3 Buchst. e, f und h DSGVO

Art. 28 verlangt die Unterstützung, sagt aber nichts über ihren Preis. Die Parteien vereinbaren ihn hier: entweder im Preis des Hauptvertrags enthalten oder die Entgelte ausgeschrieben.

15. Laufzeit und Kündigung

15.1 Dieser Vertrag tritt am DATUM DES BEGINNS in Kraft. Er gilt, solange der Auftragsverarbeiter personenbezogene Daten im Auftrag des Verantwortlichen verarbeitet, auch nach dem Ende des Hauptvertrags, sofern er nicht vorher nach Ziffer 15.2 oder Ziffer 15.3 gekündigt wird. Ziffer 15.4 regelt, was nach seinem Ende gilt.

Art. 28 Abs. 3 Unterabs. 1 DSGVO (Dauer)

Der Vertrag gilt, solange der Auftragsverarbeiter die Daten hat, nicht nur solange die Leistung läuft. Endet er früher, sorgt Ziffer 15.4 dafür, dass er bis zur Löschung der Daten weiter gilt.

15.2 Der Auftragsverarbeiter informiert den Verantwortlichen unverzüglich, wenn er diesen Vertrag aus welchem Grund auch immer nicht mehr einhalten kann. Verstößt der Auftragsverarbeiter gegen diesen Vertrag oder die DSGVO, kann der Verantwortliche ihn anweisen, die Verarbeitung auszusetzen, bis er die Pflichten wieder einhält. Wird die Einhaltung nicht innerhalb von ANZAHL Tagen wiederhergestellt oder ist der Verstoß schwerwiegend oder anhaltend, kann der Verantwortliche diesen Vertrag und die Teile des Hauptvertrags kündigen, die die Verarbeitung betreffen.

Beschluss 2021/915, Anhang, Klausel 10 Buchst. a und b

Der Verantwortliche kann die Verarbeitung stoppen und den Vertrag beenden, wenn der Auftragsverarbeiter den Mangel nicht behebt. Die Klauseln der Kommission erlauben höchstens einen Monat.

15.3 Hält der Verantwortliche an einer Weisung fest, die der Auftragsverarbeiter nach Ziffer 4.3 als Verstoß gegen das Datenschutzrecht gemeldet hat, kann der Auftragsverarbeiter diesen Vertrag und die Teile des Hauptvertrags kündigen, die die Verarbeitung betreffen.

EDSA-Leitlinien 07/2020, Ziffer 149; Beschluss 2021/915, Anhang, Klausel 10 Buchst. c

Der Auftragsverarbeiter ist an eine rechtswidrige Weisung nicht gebunden: Er kann den Vertrag beenden.

15.4 Nach dem Ende dieses Vertrags, gleich aus welchem Grund, hält der Auftragsverarbeiter ihn vollständig ein, bis alle personenbezogenen Daten gelöscht oder zurückgegeben sind. Die Ziffern 5, 12 und 14 gelten danach für Pflichten und Ansprüche fort, die vorher entstanden sind.

Beschluss 2021/915, Anhang, Klausel 10 Buchst. d; Art. 28 Abs. 3 Buchst. g DSGVO

Der ganze Vertrag gilt weiter, bis die Daten weg sind. Verschwiegenheit, Überprüfungen und Haftung gelten danach für das fort, was vorher geschah.

16. Form, Änderungen und anwendbares Recht

16.1 Dieser Vertrag und jede Änderung werden schriftlich abgefasst, was auch in einem elektronischen Format erfolgen kann.

Art. 28 Abs. 9 DSGVO

Eine mündliche oder stillschweigende Vereinbarung zählt nicht; eine elektronische schon.

16.2 Der Auftragsverarbeiter teilt jede vorgeschlagene Änderung dieses Vertrags dem Verantwortlichen direkt mit. Eine Änderung wird erst wirksam, wenn der Verantwortliche ihr schriftlich zustimmt. Die Veröffentlichung einer Änderung auf der Website des Auftragsverarbeiters ist keine Mitteilung.

EDSA-Leitlinien 07/2020, Ziffer 110

Änderungen werden mit dem Verantwortlichen vereinbart, nicht online veröffentlicht.

16.3 Dieser Vertrag unterliegt dem Recht von MITGLIEDSTAAT. Gerichtsstand ist ORT. Das Recht betroffener Personen, nach Art. 79 und Art. 82 Abs. 6 DSGVO Klage zu erheben, bleibt unberührt.

Art. 79 und Art. 82 Abs. 6 DSGVO

Die DSGVO bestimmt weder das anwendbare Recht noch das Gericht für diesen Vertrag: Die Parteien wählen sie nach allgemeinem Vertragsrecht. Betroffene Personen behalten ihr eigenes Klagerecht nach Art. 79 und Art. 82 Abs. 6.

FÜR DEN VERANTWORTLICHEN: NAME, FUNKTION, ORT, DATUM UND UNTERSCHRIFT _____ FÜR DEN AUFTRAGSVERARBEITER: NAME, FUNKTION, ORT, DATUM UND UNTERSCHRIFT _____

Anlagen

Anlage 1: Beschreibung der Verarbeitung

Beschreiben Sie jeden Punkt konkret und streichen Sie dann die Beispiele in den Feldern.

PUNKT	BESCHREIBUNG
Gegenstand	WAS DER AUFTRAGSVERARBEITER TUT, ZUM BEISPIEL LOHNABRECHNUNG FÜR DIE BESCHÄFTIGTEN
Dauer	GENAUER ZEITRAUM ODER DIE KRITERIEN, DIE IHN BESTIMMEN
Art der Verarbeitung	DIE VORGÄNGE, ZUM BEISPIEL ERHEBEN, SPEICHERN, ABFRAGEN, ÜBERMITTELN, LÖSCHEN
Zweck oder Zwecke	WOZU DIE DATEN VERARBEITET WERDEN
Art der personenbezogenen Daten	ZUM BEISPIEL NAME, ANSCHRIFT, BANKVERBINDUNG, ARBEITSZEITEN
Besondere Kategorien (Art. 9) oder Daten über Straftaten (Art. 10) und die zusätzlichen Garantien	WELCHE DATEN UND WELCHE GARANTIEN, ODER: KEINE
Kategorien betroffener Personen	ZUM BEISPIEL BESCHÄFTIGTE, KUNDEN, BESUCHER
Orte der Verarbeitung	LÄNDER UND STANDORTE, AUCH DIE DER UNTERAUFTRAGSVERARBEITER

Anlage 2: Technische und organisatorische Maßnahmen

Beschreiben Sie jede Maßnahme, die der Auftragsverarbeiter tatsächlich anwendet, konkret, und den Nachweis dafür. Die Liste nennt Bereiche, die abzudecken sind; sie sagt nicht, welche Maßnahmen genügen. Das hängt vom Risiko ab (Art. 32).

Der Musteranhang der Kommission sagt: *„Die technischen und organisatorischen Maßnahmen müssen konkret beschrieben werden; eine allgemeine Beschreibung ist nicht ausreichend“* (Beschluss 2021/915, Anhang III). Die Bereiche unten folgen Art. 32 Abs. 1 DSGVO und den Beispielen in diesem Anhang.

Teil A. Sicherheit der Verarbeitung

BEREICH	ANGEWANDTE MASSNAHMEN	NACHWEIS
Pseudonymisierung und Verschlüsselung personenbezogener Daten (Art. 32 Abs. 1 Buchst. a)	MASSNAHMEN	NACHWEIS
Dauerhafte Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit der Systeme und Dienste (Art. 32 Abs. 1 Buchst. b)	MASSNAHMEN	NACHWEIS
Rasche Wiederherstellung der Verfügbarkeit der Daten und des Zugangs zu ihnen nach einem Zwischenfall (Art. 32 Abs. 1 Buchst. c)	MASSNAHMEN	NACHWEIS
Regelmäßige Überprüfung, Bewertung und Evaluierung der Maßnahmen (Art. 32 Abs. 1 Buchst. d)	MASSNAHMEN	NACHWEIS
Identifizierung und Autorisierung der Nutzer	MASSNAHMEN	NACHWEIS
Schutz der Daten bei der Übermittlung	MASSNAHMEN	NACHWEIS
Schutz der Daten bei der Speicherung	MASSNAHMEN	NACHWEIS
Physische Sicherheit der Orte, an denen Daten verarbeitet werden	MASSNAHMEN	NACHWEIS
Protokollierung von Ereignissen	MASSNAHMEN	NACHWEIS
Systemkonfiguration, einschließlich der Standardkonfiguration	MASSNAHMEN	NACHWEIS
Interne Governance und Verwaltung der IT und der IT-Sicherheit	MASSNAHMEN	NACHWEIS
Zertifizierung oder Qualitätssicherung von Prozessen und Produkten	MASSNAHMEN	NACHWEIS
Datenminimierung	MASSNAHMEN	NACHWEIS
Datenqualität	MASSNAHMEN	NACHWEIS
Begrenzte Speicherdauer	MASSNAHMEN	NACHWEIS
Rechenschaftspflicht	MASSNAHMEN	NACHWEIS
Datenübertragbarkeit und Löschung	MASSNAHMEN	NACHWEIS

Teil B. Unterstützung des Verantwortlichen

PFLICHT DES VERANTWORTLICHEN	WIE DER AUFTRAGSVERARBEITER HILFT
Beantwortung von Anträgen betroffener Personen (Art. 28 Abs. 3 Buchst. e)	ZUM BEISPIEL WEITERLEITUNG IN DER VEREINBARTEN FRIST, EXPORT, LÖSCHUNG AUF WEISUNG
Sicherheit der Verarbeitung (Art. 32)	BESCHREIBEN
Meldung und Benachrichtigung bei Verletzungen (Art. 33 und 34)	BESCHREIBEN, AUCH DIE KONTAKTSTELLE UND DEN INHALT DER MELDUNG
Folgenabschätzungen und vorherige Konsultation (Art. 35 und 36)	BESCHREIBEN

Anlage 3: Unterauftragsverarbeiter

Führen Sie jeden Unterauftragsverarbeiter auf jeder Stufe der Kette auf. Bei Option A ist das die Liste der genehmigten Unterauftragsverarbeiter; bei Option B die vereinbarte Liste.

NAME UND ANSCHRIFT	ANSPRECHPARTNER	VERARBEITUNGSTÄTIGKEIT	LAND	ÜBERMITTLUNGSINSTRUMENT, FALLS AUSSERHALB DES EWR	GENEHMIGT AM
NAME UND ANSCHRIFT	KONTAKT	TÄTIGKEIT	LAND	INSTRUMENT ODER: KEINES	DATUM
NAME UND ANSCHRIFT	KONTAKT	TÄTIGKEIT	LAND	INSTRUMENT ODER: KEINES	DATUM

Mit jedem Antrag oder jeder angekündigten Änderung übermittelt der Auftragsverarbeiter die Identität des Unterauftragsverarbeiters, seinen Ort, seine Tätigkeit und seine Garantien (EDSA-Leitlinien 07/2020, Ziffer 152, S. 49).

Anlage 4: Kontaktstellen

Nennen Sie für jede Rolle eine Person und einen Kanal und halten Sie die Liste aktuell.

ROLLE	VERANTWORTLICHER	AUFTRAGSVERARBEITER
Erteilung und Empfang von Weisungen	NAME, FUNKTION, E-MAIL	NAME, FUNKTION, E-MAIL
Meldungen von Verletzungen des Schutzes personenbezogener Daten	NAME, E-MAIL, TELEFON	NAME, E-MAIL, TELEFON
Anträge betroffener Personen	NAME, E-MAIL	NAME, E-MAIL
Überprüfungen und Auskunftsersuchen	NAME, E-MAIL	NAME, E-MAIL
Datenschutzbeauftragter, falls benannt	NAME UND KONTAKT	NAME UND KONTAKT

Erfüllt Ihr bestehender Vertrag Art. 28 Abs. 3?

Lesen Sie den bereits unterschriebenen Vertrag und kreuzen Sie für jede Zeile Ja, Nein oder „?“ an. „?“ bedeutet unbekannt: Notieren Sie, wen Sie gefragt haben. Jedes Nein ist eine Lücke gegenüber dem Artikel.

PUNKT	INHALT	JA	NEIN	?
Art. 28 Abs. 3 Unterabs. 1 DSGVO	Er legt Gegenstand und Dauer der Verarbeitung, Art und Zweck der Verarbeitung, die Art der personenbezogenen Daten, die Kategorien betroffener Personen sowie die Pflichten und Rechte des Verantwortlichen fest.	☐	☐	☐
Art. 28 Abs. 3 Buchst. a DSGVO	Der Auftragsverarbeiter verarbeitet nur auf dokumentierte Weisung des Verantwortlichen, auch bei Übermittlungen in Drittländer oder an internationale Organisationen. Verlangt ein Gesetz der Union oder eines Mitgliedstaats etwas anderes, teilt er das vorher mit, sofern dieses Gesetz die Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.	☐	☐	☐
Art. 28 Abs. 3 Buchst. b DSGVO	Der Auftragsverarbeiter gewährleistet, dass sich die befugten Personen zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.	☐	☐	☐
Art. 28 Abs. 3 Buchst. c DSGVO	Der Auftragsverarbeiter ergreift alle nach Art. 32 erforderlichen Sicherheitsmaßnahmen.	☐	☐	☐
Art. 28 Abs. 3 Buchst. d DSGVO	Der Auftragsverarbeiter hält die Bedingungen des Art. 28 Abs. 2 und 4 für die Inanspruchnahme eines weiteren Auftragsverarbeiters ein.	☐	☐	☐
Art. 28 Abs. 3 Buchst. e DSGVO	Der Auftragsverarbeiter unterstützt den Verantwortlichen angesichts der Art der Verarbeitung nach Möglichkeit mit geeigneten technischen und organisatorischen Maßnahmen bei der Beantwortung von Anträgen betroffener Personen.	☐	☐	☐
Art. 28 Abs. 3 Buchst. f DSGVO	Der Auftragsverarbeiter unterstützt den Verantwortlichen unter Berücksichtigung der Art der Verarbeitung und der ihm verfügbaren Informationen bei den Pflichten nach den Art. 32 bis 36 (Sicherheit, Meldung und Benachrichtigung bei Verletzungen, Folgenabschätzungen, vorherige Konsultation).	☐	☐	☐
Art. 28 Abs. 3 Buchst. g DSGVO	Nach dem Ende der Leistungen löscht der Auftragsverarbeiter nach Wahl des Verantwortlichen alle personenbezogenen Daten oder gibt sie zurück und löscht die vorhandenen Kopien, sofern nicht eine Speicherpflicht nach dem Recht der Union oder der Mitgliedstaaten besteht.	☐	☐	☐
Art. 28 Abs. 3 Buchst. h DSGVO	Der Auftragsverarbeiter stellt alle Informationen zum Nachweis der Einhaltung von Art. 28 zur Verfügung und ermöglicht Überprüfungen, einschließlich Inspektionen, durch den Verantwortlichen oder einen von ihm beauftragten Prüfer und trägt dazu bei.	☐	☐	☐
Art. 28 Abs. 3 Unterabs. 2 DSGVO	Der Auftragsverarbeiter informiert den Verantwortlichen unverzüglich, falls er der Auffassung ist, dass eine Weisung gegen die DSGVO oder gegen andere Datenschutzbestimmungen der Union oder der Mitgliedstaaten verstößt.	☐	☐	☐
Art. 28 Abs. 2 DSGVO	Der Auftragsverarbeiter nimmt einen weiteren Auftragsverarbeiter nur mit vorheriger gesonderter oder allgemeiner schriftlicher Genehmigung des Verantwortlichen in Anspruch. Bei einer allgemeinen Genehmigung informiert er über jede beabsichtigte Hinzuziehung oder Ersetzung, sodass der Verantwortliche Einspruch erheben kann.	☐	☐	☐
Art. 28 Abs. 4 DSGVO	Jeder Unterauftragsverarbeiter ist durch Vertrag oder anderes Rechtsinstrument an dieselben Datenschutzpflichten gebunden, und der Auftragsverarbeiter haftet gegenüber dem Verantwortlichen für dessen Pflichterfüllung.	☐	☐	☐
Art. 28 Abs. 9 DSGVO	Der Vertrag ist schriftlich abgefasst, was auch in einem elektronischen Format erfolgen kann.	☐	☐	☐

Bußgeld verhängt, Art. 28 DSGVO unter den Verstößen

Serfin 97 S.r.l., Auftragsverarbeiter: 60.000 Euro, Garante für den Schutz personenbezogener Daten (Italien), 2024; er ergänzte eigenmächtig Kontaktdaten, ohne die Quelle festzuhalten oder sie an den Verantwortlichen weiterzugeben; Art. 28 Abs. 3 Buchst. a, e und h DSGVO unter den Verstößen (2024/IT/132). ISWEB S.p.A.: 40.000 Euro, Garante, 2022; sie setzte einen Hosting-Anbieter ohne ordnungsgemäße Vereinbarung nach Art. 28 ein, auch ohne vorherige Genehmigung eines Kunden; Art. 28 Abs. 1, 2, 3 und 4 DSGVO unter den Verstößen (2022/IT/103). Entscheidungsseiten auf Englisch. Jede Geldbuße betrifft alle festgestellten Verstöße, nicht nur diesen Artikel.

DEUTSCHLAND

Deutschland

Begriffe. Der Vertrag heißt *Vereinbarung zur Auftragsverarbeitung* (BfDI) oder *Auftragsverarbeitungsvertrag* (mehrere Landesbehörden). Die Begriffe der DSGVO sind *Auftragsverarbeiter* und *Verantwortlicher*.

Das Muster des BfDI. Die oder der Bundesbeauftragte für den Datenschutz und die Informationsfreiheit (BfDI) veröffentlicht eine *Mustervereinbarung zur Auftragsverarbeitung*, Version 2.1, geschrieben für öffentliche Stellen des Bundes: Verantwortlicher ist darin die Bundesrepublik Deutschland, vertreten durch eine öffentliche Stelle (BfDI-Muster). Über den bloßen Artikel hinaus sieht es vor: ein Recht des Auftragsverarbeiters, eine für rechtswidrig gehaltene Weisung auszusetzen, bis der Verantwortliche sie bestätigt oder ändert (§ 3 Abs. 5; vergleiche Ziffer 4.3); eine Anlage mit den Weisungsberechtigten und Weisungsempfängern (vergleiche Anlage 4); eine Frist von *„mindestens vier Wochen“* vor einem neuen Unterauftragnehmer, bei der gesonderten wie bei der allgemeinen Genehmigung (§ 8 Abs. 1; vergleiche Ziffern 7.1 und 7.2); die vorherige Zustimmung des Verantwortlichen für eine Verarbeitung außerhalb der Betriebsräume des Auftragsverarbeiters, etwa im Homeoffice (§ 3 Abs. 11); und einen schlichten Verweis auf Art. 82 DSGVO für die Haftung (§ 10).

DE-3.11 Der Auftragsverarbeiter verarbeitet die personenbezogenen Daten außerhalb seiner Betriebsräume, auch durch Beschäftigte im Homeoffice, nur mit vorheriger Zustimmung des Verantwortlichen in Schriftform oder in dokumentierter elektronischer Form.

BfDI, Mustervereinbarung zur Auftragsverarbeitung, Version 2.1, § 3 Abs. 11

Freiwillig: Das BfDI-Muster macht die Arbeit an den Daten außerhalb der Betriebsräume von der Zustimmung des Verantwortlichen abhängig. Es ist eine Musterklausel, keine Anforderung der DSGVO.

Quelle der BfDI-Punkte: „Der Bundesbeauftragte für den Datenschutz und die Informationsfreiheit", Mustervereinbarung zur Auftragsverarbeitung, Version 2.1, verwendet unter der Datenlizenz Deutschland – Namensnennung – Version 2.0 (www.govdata.de/dl-de/by-2-0).

Das DSK-Kurzpapier. Die Datenschutzkonferenz (DSK) erläutert Art. 28 im *Kurzpapier Nr. 13* (Stand: 17. Dezember 2018). Die DSK führt es als *„in Überarbeitung"* (DSK-Liste der Kurzpapiere), und das Papier selbst sagt: *„Diese Auffassung steht unter dem Vorbehalt einer zukünftigen - möglicherweise abweichenden - Auslegung des Europäischen Datenschutzausschusses"* (DSK Kurzpapier Nr. 13, S. 1). Danach ist die IT-Wartung oder Fernwartung, bei der ein Zugriff auf personenbezogene Daten nicht ausgeschlossen werden kann, Auftragsverarbeitung, sodass Art. 28 gilt, eine rein technische Wartung der Infrastruktur, etwa an Stromzufuhr, Kühlung oder Heizung, dagegen nicht. Die Einbeziehung eines Berufsgeheimnisträgers wie Steuerberater, Rechtsanwälte, externe Betriebsärzte oder Wirtschaftsprüfer ist nach dem Kurzpapier *„in der Regel"* keine Auftragsverarbeitung, sondern die Inanspruchnahme eines eigenständig Verantwortlichen (Anhang B).

Die späteren Leitlinien des EDSA beantworten den Fall einer Wirtschaftsprüfungsgesellschaft mit einem Vorbehalt: Im Beispiel des EDSA ist sie eigenständiger Verantwortlicher; sieht das Gesetz aber keine besonderen Pflichten für sie vor und erteilt der Kunde sehr detaillierte Weisungen, handelt sie als Auftragsverarbeiter (EDSA-Leitlinien 07/2020, Beispiel „Wirtschaftsprüfer", S. 18). Die Rolle hängt von den Umständen jedes Auftrags ab.

Quelle der DSK-Punkte: Konferenz der unabhängigen Datenschutzbehörden des Bundes und der Länder (Datenschutzkonferenz). Datenlizenz Deutschland – Namensnennung – Version 2.0 (www.govdata.de/dl-de/by-2-0).

Berufsgeheimnis (§ 203 Strafgesetzbuch, StGB). Für Ärztinnen und Ärzte, Rechtsanwältinnen und Rechtsanwälte und die anderen in § 203 Abs. 1 und 2 StGB genannten Berufsgeheimnisträger ist Art. 28 nicht die einzige Regel. Sie dürfen Geheimnisse sonstigen Personen offenbaren, die an ihrer beruflichen oder dienstlichen Tätigkeit mitwirken, *„soweit dies für die Inanspruchnahme der Tätigkeit der sonstigen mitwirkenden Personen erforderlich ist"* (§ 203 Abs. 3). Sie machen sich strafbar, wenn eine solche Person ein Geheimnis unbefugt offenbart und sie nicht dafür Sorge getragen haben, dass diese *„zur Geheimhaltung verpflichtet wurde"* (§ 203 Abs. 4 Satz 2 Nr. 1) (gesetze-im-internet.de). Das DSK-Kurzpapier stellt denselben Zusammenhang her (Kurzpapier Nr. 13, S. 2).

DE-5.3 Unterliegt der Verantwortliche einem Berufsgeheimnis nach § 203 Abs. 1 oder 2 StGB, gilt: Der Auftragsverarbeiter ist verpflichtet, alle fremden Geheimnisse, die ihm bei der Durchführung dieses Vertrags bekannt werden, geheim zu halten; er verschafft sich von ihnen nur Kenntnis, soweit dies für seine Tätigkeit erforderlich ist, und verpflichtet jede weitere Person, die er für diese Tätigkeit einsetzt, vor Beginn ihrer Tätigkeit zur Geheimhaltung.

§ 203 Abs. 3 und 4 StGB

Freiwillig, in eigener Formulierung von Fino, für Ärzte, Rechtsanwälte, Steuerberater und andere Berufsgeheimnisträger in Deutschland. Nach § 203 Abs. 4 StGB macht sich der Berufsgeheimnisträger strafbar, wenn eine mitwirkende Person ein Geheimnis unbefugt offenbart und er nicht dafür gesorgt hat, dass sie zur Geheimhaltung verpflichtet wurde. Diese Klausel ist eine Möglichkeit, die Verpflichtung festzuhalten. Berufsrecht kann mehr verlangen, zum Beispiel für Rechtsanwälte § 43e Abs. 3 BRAO: „Der Vertrag mit dem Dienstleister bedarf der Textform", und der Dienstleister ist „unter Belehrung über die strafrechtlichen Folgen einer Pflichtverletzung zur Verschwiegenheit zu verpflichten" (§ 43e BRAO).

Bußgeld verhängt, Art. 28 DSGVO unter den Verstößen

Volkswagen: 1.100.000 Euro, Landesbeauftragter für den Datenschutz Niedersachsen, 2022. Unter vier Verstößen gab es keinen Vertrag zur Auftragsverarbeitung mit dem Dienstleister, der die Forschungsfahrten mit Aufzeichnung des Verkehrs durchführte (2022/DE/050). **Vodafone GmbH**: 45.000.000 Euro in zwei Geldbußen, rechtskräftig, Bundesbeauftragte für den Datenschutz und die Informationsfreiheit (BfDI), 2025. 15 Millionen Euro davon wurden verhängt, weil Vodafone seine Partneragenturen nicht ausreichend überprüft und überwacht hatte (Art. 28 Abs. 1) (2025/DE/006). Entscheidungsseiten auf Englisch.

Die Angaben zu den Entscheidungen stammen von enforcementtracker.com (betrieben von CMS) und GDPRhub (noyb) unter CC BY-NC-SA 4.0 (https://creativecommons.org/licenses/by-nc-sa/4.0/) sowie aus den Veröffentlichungen der Behörden selbst; jede Entscheidungsseite auf Fino nennt die Einzelheiten.

Quellen

Datenschutz-Grundverordnung (DSGVO), Verordnung (EU) 2016/679, deutsche Fassung (EUR-Lex) • Verwendet für: Art. 4, 24, 28, 29, 32, 33, 44 bis 47, 79, 82; die Artikel sind im Text direkt verlinkt

Durchführungsbeschluss (EU) 2021/915 der Kommission, Standardvertragsklauseln zwischen Verantwortlichen und Auftragsverarbeitern, deutsche Fassung (EUR-Lex) • Verwendet für: Der Weg nach Art. 28 Abs. 7; Unabänderbarkeit; Übermittlungen nicht erfasst; Wortlaut der Meldung; Bereiche des Anhangs III; Aufbau der Beendigung

EDSA, Leitlinien 07/2020 zu den Begriffen „Verantwortlicher" und „Auftragsverarbeiter" in der DSGVO, deutsche Fassung, Version 2.0 • Verwendet für: Wer Auftragsverarbeiter ist; Inhalt und Genauigkeit des Vertrags; Weisungen, Sicherheit, Unterauftragsverarbeiter, Meldefrist, Löschung, Überprüfungen und Kosten, rechtswidrige Weisungen

EDSA, Stellungnahme 22/2024 zu bestimmten Verpflichtungen, die sich aus der Inanspruchnahme von Auftragsverarbeitern und Unterauftragsverarbeitern ergeben, deutsche Fassung • Verwendet für: Identität aller Unterauftragsverarbeiter; die Wendung zur gesetzlichen Verpflichtung

Gemeinsame Stellungnahme 1/2021 von EDSA und EDSB zu den Standardvertragsklauseln zwischen Verantwortlichen und Auftragsverarbeitern (auf Englisch) • Verwendet für: Meldefrist den Parteien überlassen (Ziffer 42)

EDSA-Register: Standardvertragsklauseln und Verwaltungsvereinbarungen (auf Englisch) • Verwendet für: Klauseln von Aufsichtsbehörden nach Art. 28 Abs. 8 (gelesen am 7. November 2026)

Durchführungsbeschluss (EU) 2021/914 der Kommission, Standardvertragsklauseln für Übermittlungen, deutsche Fassung (EUR-Lex) • Verwendet für: Vorrang der Übermittlungsklauseln (Klausel 5)

BfDI: Mustervereinbarung zur Auftragsverarbeitung, Version 2.1 (Datenlizenz Deutschland – Namensnennung – Version 2.0) • Verwendet für: Aufbau und Musterregelungen (Aussetzung, Weisungsanlage, vier Wochen, Homeoffice, Haftung)

DSK: Kurzpapier Nr. 13, Auftragsverarbeitung, Art. 28 DS-GVO (Stand: 17. Dezember 2018, in Überarbeitung); Konferenz der unabhängigen Datenschutzbehörden des Bundes und der Länder (Datenschutzkonferenz). Datenlizenz Deutschland – Namensnennung – Version 2.0 (www.govdata.de/dl-de/by-2-0) • Verwendet für: Wartung und Fernzugriff, Berufsgeheimnisträger, § 203 StGB

Bundesrechtsanwaltsordnung (BRAO), § 43e (gesetze-im-internet.de) • Verwendet für: Berufsrecht der Rechtsanwälte beim Einsatz von Dienstleistern

Strafgesetzbuch, § 203 (gesetze-im-internet.de) • Verwendet für: Berufsgeheimnis beim Einsatz eines Auftragsverarbeiters

Datatilsynet (Dänemark): Standardvertragsklauseln für Art. 28 Abs. 3, englische Vorlage • Verwendet für: Nur Aufbau (Reihenfolge von Klauseln und Anlagen); kein Wortlaut übernommen

Datenschutzbehörde (Österreich): Standardvertragsklauseln für die Zwecke nach Art. 28 DSGVO (Jänner 2020) • Verwendet für: Nur Aufbau; kein Wortlaut übernommen